



# Non-ripudio nel mondo elettronico

- *Devi aver ricevuto l'e-coin!*
- *Non ho mai comprato quel tipo di servizio!*
- *Ora posso rappresentarlo in quest'affare!*
- *Ti avevo dato la responsabilità!*
- *Sicuramente quest'e-mail proviene da te!*
- *Devi aver beccato il mio messaggio e-mail!*
- ...



# Parallelo

|                     | Mondo reale                                                               | Mondo elettronico                                            |
|---------------------|---------------------------------------------------------------------------|--------------------------------------------------------------|
| Misure di sicurezza | Bancomat robusti<br>Casseforti<br>Lucchetti<br>...                        | Crypto<br>Protocolli di sicurezza<br>Firewall<br>...         |
| Contromisure        | Telecamere<br>Registrazioni<br>Non-ripudio<br>...<br>Polizia<br>Tribunale | Intrusion management<br><b>Non-ripudio</b><br>?<br>Tribunale |



# Non-ripudio

**Def.** Disponibilità di evidenza inequivocabile che impedisca a un soggetto di negare proprie azioni

- Inequivocabile: dimostrabile in Tribunale
- Firma elettronica
  - La elettronica ha un certo valore legale in Italia
- Equità
  - Coinvolti 2 agenti, ottengano garanzie analoghe



# Sommario

- Vedremo 3 problemi di non-ripudio nel mondo elettronico
  1. Compravendita
  2. Delega
  3. E-mail
- Problemi **molto** simili ma ambiti diversi



# Fattori determinanti

## 1. Affidabilità del mezzo

- ☐ *Non l'ho mai ricevuto!*

## 2. Onestà dei partecipanti

- ☐ *Ho quello che mi serve, chiudo!*

- ☐ *E se gli mando un siffatto messaggio?*

Tutte le 4 combinazioni sono possibili



# Modello di attaccante

- Quale modello è adeguato per il non-ripudio:
  - ☐ DY ?
  - ☐ BUG ?



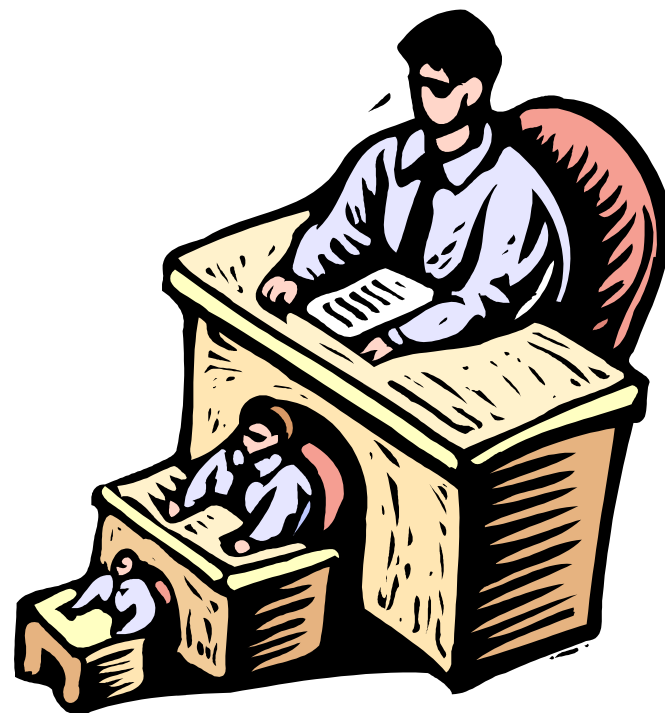
# 1. Non-ripudio in compravendita

## ■ Reale vs. elettronica

Ti ho mandato il denaro.  
Dov'è la merce??



Ti ho mandato la merce.  
Dov'è il denaro??





# Protocolli di compravendita

## ■ Precondizioni

- ☐ Generici agenti A e B
- ☐ PKI
- ☐ Messaggio m cruciale per la compravendita
  - *un ordine, un e-coin, etc.*
- ☐ TTP (solo alcuni)
- ☐ Aggiuntive a seconda del caso

## ■ Goal: **equa compravendita**





# Equa compravendita

**Def.** A spedisca a B un messaggio  $m$  in modo tale che A ottenga evidenza che B l'abbia ricevuto se e solo se B ottenga evidenza che A l'abbia spedito

- Nessuno dei due ha un vantaggio sull'altro



# Idealizzazione A

■ Precondizioni aggiuntive

■ Goal OK?

□ **Mezzo affidabile**

□ **Agenti onesti**

1.  $A \longrightarrow B : f_{nro}, B, m, \text{Sign}_A(f_{nro}, B, m)$
2.  $B \longrightarrow A : f_{nrr}, A, \text{Sign}_B(f_{nrr}, A, m)$



# Idealizzazione B

- Precondizioni aggiuntive
- Goal OK?
- **Mezzo affidabile**
- **Agenti disonesti**

1.  $A \longrightarrow TTP : f_{nro}, TTP, B, m,$   
 $\text{Sign}_A(f_{nro}, TTP, B, m)$
2.  $TTP \longrightarrow B : f_{nrs}, A, B, m,$   
 $\text{Sign}_{TTP}(f_{nrs}, A, B, m)$
3.  $TTP \longrightarrow A : f_{nrd}, A, B,$   
 $\text{Sign}_{TTP}(f_{nrd}, A, B, m)$



# Idealizzazione C

- Precondizioni aggiuntive
- Goal OK?
- **Mezzo inaffidabile**
- **Agenti onesti**

1.  $A \longrightarrow B : f_{nro}, B, m, \text{Sign}_A(f_{nro}, B, m)$
2.  $B \longrightarrow A : f_{nrr}, A, \text{Sign}_B(f_{nrr}, A, m)$
3.  $A \longrightarrow B : f_{ack}, B, \text{Sign}_A(f_{ack}, B, m)$



# Situazione reale

- Precondizioni aggiuntive
  - **Mezzo inaffidabile**
  - **Agenti disonesti**
- Strategia a rilascio posticipato
  - Inizialmente dare il crittotesto al ricevente
  - Se il ricevente è interessato a decodificare il crittotesto deve continuare la sessione
  - Mentre continua dà evidenza di partecipazione
  - Infine dare al ricevente la chiave



# Tentativo

1.  $A \longrightarrow B : f_{poe}, B, c, \text{Sign}_A(f_{poe}, B, c)$
2.  $B \longrightarrow A : f_{acp}, A, \text{Sign}_B(f_{acp}, A, c)$
3.  $A \longrightarrow B : f_{nro}, B, k, \text{Sign}_A(f_{nro}, B, k)$
4.  $B \longrightarrow A : f_{nrr}, A, \text{Sign}_B(f_{nrr}, A, k)$

## ■ Goal OK?

□ B manderà l'ultimo messaggio?



# Protocollo Zhou-Gollmann

- Garantisce il goal di equa compravendita nella situazione reale
- Implementa la strategia a rilascio posticipato
- Ricorre a un TTP
- Utilizza FTP



# Abbreviazioni

$$c = m_k$$

$$NRO = \text{Sign}_A(f_{nro}, B, L, c)$$

$$NRR = \text{Sign}_B(f_{nrr}, A, L, c)$$

$$sub_k = \text{Sign}_A(f_{sub}, B, L, k)$$

$$con_k = \text{Sign}_{\text{TPP}}(f_{con}, A, B, L, k)$$





# Protocollo

1.  $A \longrightarrow B : f_{nro}, B, L, c, NRO$

2.  $B \longrightarrow A : f_{nrr}, A, L, NRR$

3.  $A \longrightarrow TTP : f_{sub}, B, L, k, sub\_k$

4.  $B \xleftarrow{FTP} TTP : f_{con}, A, B, L, k, con\_k$

5.  $A \xleftarrow{FTP} TTP : f_{con}, A, B, L, k, con\_k$



# Analisi

- Non ci guadagna (perché?)
  - B a terminare dopo il passo 1
  - A a terminare dopo il passo 2
- Dopo il passo 3 nessuno può imbrogliare per via della disponibilità di  $k$  presso TTP
  - Gli agenti sono tenuti a ritirare  $k$



# Risoluzione dispute

- Ambedue gli agenti arrivano alla fine della sessione ottenendo rispettivamente

| A                                                        | B                                                        |
|----------------------------------------------------------|----------------------------------------------------------|
| $NR R = \text{Sign}_B(f_{nrr}, A, L, c)$                 | $NR O = \text{Sign}_A(f_{nro}, B, L, c)$                 |
| $con\_k = \text{Sign}_{\text{TTT}}(f_{con}, A, B, L, k)$ | $con\_k = \text{Sign}_{\text{TTT}}(f_{con}, A, B, L, k)$ |

- Evidenza da Tribunale (ruolo di L)
  - Valida (perché?)
  - Equa (perché?)



# TTP

- E' **stateful**: mantiene il log delle transazioni per sempre
  - L'opposto di **stateless**
  - Potenziale limite nella realtà
- Se non lo fosse, il protocollo sarebbe vulnerabile a un replay attack



# Approfondimenti

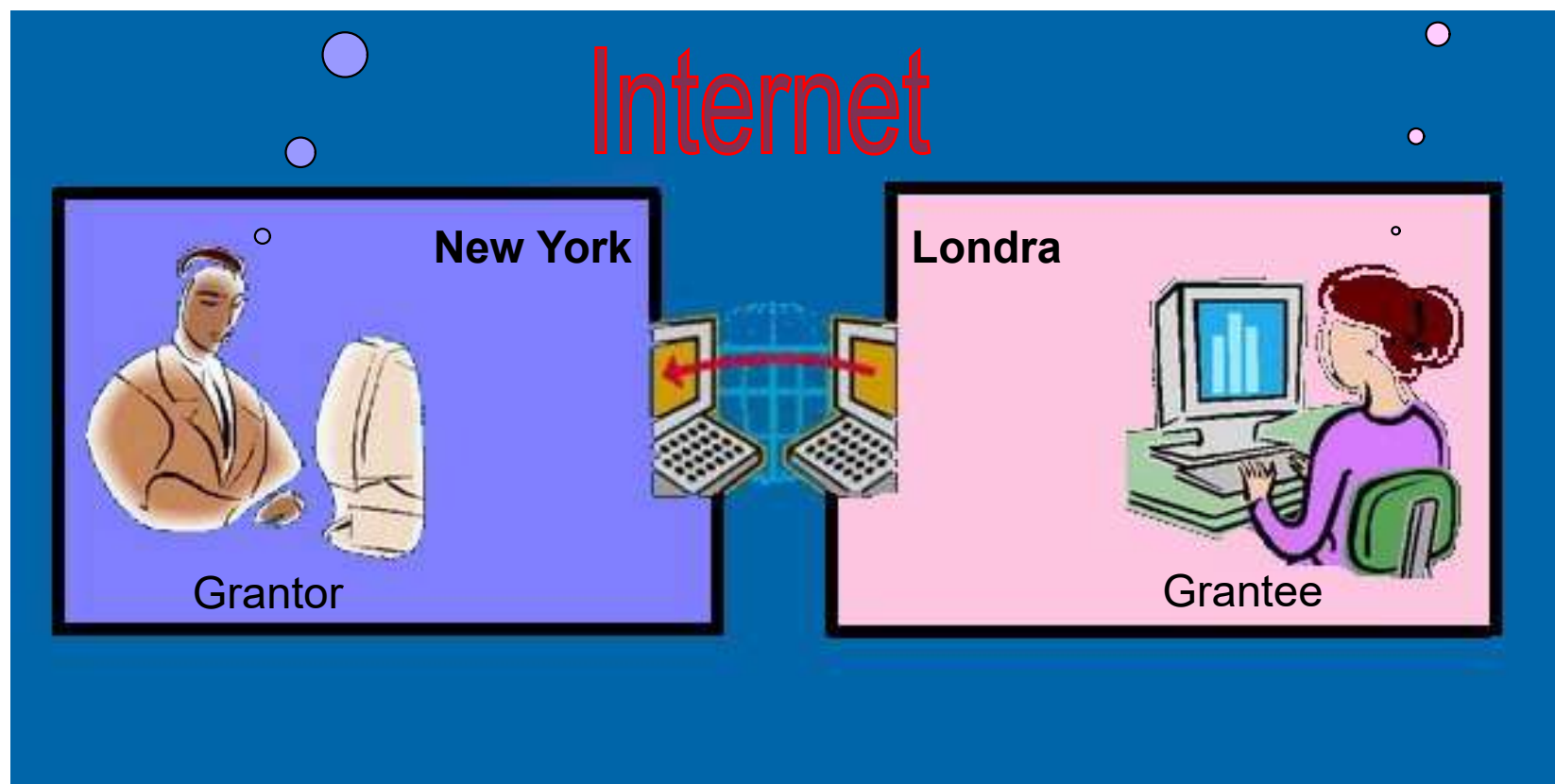
- Cercare replay attack su Zhou-Gollmann qualora TTP non fosse stateful
- Studiare varianti del protocollo (fair, efficient, ...)
  - TTP è ancora stateful?
- Cercare implementazioni dei protocolli visti
  - Elementi di non-ripudio in protocolli per commercio elettronico?



## 2. Non-ripudio in delega

Le delego formalmente il diritto e la responsabilità di seguire la faccenda!

OK!





# Protocollo Crispo

## ■ Precondizioni

- Grantor G, grantee g
- Compito  $\Omega$  da esercitare presso un end-point
- Chiavi di firma, certificate, per G e per g
- 3 coppie di chiavi asimmetriche, 1 usata da G, 2 da g
- Nessun TTP

## ■ Goal: **equa delega**



# Equa delega

**Def.** Il grantee riceva evidenza che il grantor gli ha dato diritto su  $\Omega$  se e solo se il grantor riceva evidenza che il grantee ha accettato responsabilità su  $\Omega$

- Nessuno dei due ha un vantaggio sull'altro
- Non costringe il grantee ad eseguire  $\Omega$ !





# Solo chiavi asimmetriche

| Compito             | Sintassi |       | Algoritmo          | Usata da | Certificazione |
|---------------------|----------|-------|--------------------|----------|----------------|
| <b>Firma</b>        | priSK    | pubSK | firma              | G e g    | Esterna        |
| <b>Delega</b>       | priDK    | pubDK | firma              | G        | Interna        |
| <b>Accettazione</b> | priAK    | pubAK | firma              | g        | Interna        |
| <b>Esercizio</b>    | priEK    | pubEK | Codifica<br>asimm. | g        | Interna        |

- Quindi la sintassi Sign va arricchita per menzionare la chiave



# Protocollo Crispo

1.  $G \longrightarrow g : \text{Sign}_{\text{priSK } G}(G, g, \Omega, \text{pubDK } G)$
2.  $g \longrightarrow G : \text{Sign}_{\text{priSK } g}(g, \Omega, \text{pubAK } g, \text{pubEK } g)$
3.  $G \longrightarrow g : \text{Sign}_{\text{priDK } G}(g, G, \Omega, \text{pubDK } G, \text{pubEK } g, \text{pubAK } g)$

- Parte in chiaro omessa
- Ricevuto 3, grantee appone la sua firma con priAK, creando il **token di delega**



# Token di delega

$$\text{Sign}_{\text{priAK } g}(\text{Sign}_{\text{priDK } G}(g, G, \Omega, \text{pubDK } G, \text{pubEK } g, \text{pubAK } g))$$

- Grantee  $g$  se lo registra
- Deve presentarlo per esercitare  $\Omega$ 
  - Ottiene il diritto di esercitarlo tramite  $\text{pubEK } g$
- $g$  vuole terminare la sessione per ottenere il token di delega



# Analisi

1.  $G \longrightarrow g : \text{Sign}_{\text{priSK } G}(G, g, \Omega, \text{pubDK } G)$
2.  $g \longrightarrow G : \text{Sign}_{\text{priSK } g}(g, \Omega, \text{pubAK } g, \text{pubEK } g)$
3.  $G \longrightarrow g : \text{Sign}_{\text{priDK } G}(g, G, \Omega, \text{pubDK } G, \text{pubEK } g, \text{pubAK } g)$

- $g$  ottiene il token di delega se e solo se  $G$  ottiene il messaggio 2
- Goal? Lieve vantaggio di  $G$ ??



# Risoluzione dispute

## ■ Inerenti diritto/responsabilità

- Se G nega di avere delegato a g diritto su  $\Omega$ , allora a g basta esibire il token di delega
- Se g nega di aver accettato da G responsabilità su  $\Omega$ , allora a G basta esibire il messaggio 2

## ■ Inerenti l'esercizio di $\Omega$

- Se g nega di aver esercitato  $\Omega$  per conto di G, allora G deve esibire il messaggio 2 **insieme** al token di delega richiesto all'end-point

- Perché?



# Approfondimenti

- Si può diminuire il numero di chiavi?
- Come mai non serve un TTP?
- Implementazioni
- Verifica formale



### 3. Non-ripudio in e-mail



An e-mail from him... what a weird protocol though...

Hmm, must send her an e-mail...

... but in such a way that she can't claim I

OK, I'll send it using that certified e-mail protocol...

Then I'll get a receipt when he sees the message!

... damn it! So he now has a receipt that I have read his message!

At least he couldn't get that receipt until I opened his email!





# Protocollo Abadi et al.

## ■ Precondizioni

- ☐ Mittente S, ricevente R, e-mail m
- ☐ **Stateless** TTP
- ☐ No PKI, solo TTP ha coppie di firma e codifica
- ☐ Ogni agente condivide una password con TTP
- ☐ S ed R preconcordano funzione  $\text{ack}(q)=r$ , sconosciuta a TTP, per autenticare R con S
- ☐ Disponibilità di SSL o simile

## ■ Goal: una forma (quale?) di **equo recapito**





# Equo recapito debole

**Def.** Il ricevente legga l'e-mail se e solo se il mittente riceva la ricevuta di ritorno

- C'è una forma di equità, per quanto debole



# Equo recapito forte

**Def.** Il ricevente legga l'e-mail, ottenendo pure evidenza che provenga dal mittente, se e solo se il mittente riceva la ricevuta di ritorno

- Più forte forma di equità



# Abbreviazioni

$$c = m_k$$

$$h_S = \text{Hash}(q, r, c)$$

$$h_R = \text{Hash}(q', r', c')$$

$$S2TTP = \{S, k, R, h_S\}_{\text{pubEK}_{TTP}}$$

$$DR = \text{Sign}_{TTP} S2TTP$$



# Protocollo

1.  $S \longrightarrow R : TTP, c, q, S2TTP$
2.  $R \xrightarrow{SSL} TTP : S2TTP, \text{pwd } R, h_R$
3.  $TTP \xrightarrow{SSL} R : k, h_R$
4.  $TTP \longrightarrow S : DR$



# Analisi

- Equo recapito OK per l'affidabilità di TTP
- Debole o forte?
- Evidente che TTP sia stateless
  - ☐ Deve solo confrontare gli hash
  - ☐ Replay attack?
- Mancanza di PKI tamponata tramite SSL



# Equo recapito forte

- Basta modificare il protocollo così
  - S inserisca sua password in S2TTP
  - Messaggio 3 menzioni S e sia firmato da TTP
- Firma di TTP su 3 necessaria per non-ripudio altrimenti avremmo solo autenticazione SSL, non da tribunale!
- Equo recapito debole più debole di equa compravendita: R non ha NRO contro S



# Approfondimenti

- Protocollo di sicurezza di secondo livello
  - Utilizza un altro protocollo di sicurezza
  - Interazioni fra i due protocolli?
- Implementazioni esistenti?
- Protocollo di Nenadic et al.